

Cybersecurity Daily Newsletter

Vol. 003 | 2026-07-25 09:00 WIB

Top 5 Highlights

- Pope's official prayer app commits cardinal sin, leaks 700K+ users' info
- Golden Chickens malware-as-a-service resurfaces with four new families
- Vatican's 'Click to Pray' app leaks personal data of hundreds of thousands
- Cybersecurity threats escalate with ransomware, data breaches and online fraud
- UK issues alert over Russian zero-click email attacks

Threat Intelligence (10)

01. Golden Chickens malware-as-a-service resurfaces with four new families

The Hacker News disclosed that the threat actors behind the Golden Chickens malware-as-a-service (MaaS) ecosystem have resurfaced with four new malware families, indicating that the operators are showing no signs of stopping despite extensive public disclosures into their inner workings.

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources:

<https://www.scworld.com/brief/golden-chickens-malware-as-a-service-resurfaces-with-four-new-families>

02. UK issues alert over Russian zero-click email attacks

The UK's National Cyber Security Centre (NCSC) issued an alert regarding a new 'zero-click' threat campaign orchestrated by Russian state-backed hackers targeting organizations across critical sectors, according to a recent report by IT Pro.

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://www.scworld.com/brief/uk-issues-alert-over-russian-zero-click-email-attacks>

03. BlueNoroff Zoom Phishing Kit Profiles Crypto Wallets Before Malware Delivery

The North Korean threat actors behind the ClickFix-style campaigns that employ typosquatted Zoom and Microsoft Teams domains have been found to operate an active phishing kit to impersonate the videoconferencing platforms in social engineering campaigns designed to deliver malware. "BlueNoroff has operationalised trust abuse by combining compromised industr...

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Tighten email authentication and filtering, run targeted user awareness, and monitor for lookalike domains and suspicious inbox rules.

Sources: <https://thehackernews.com/2026/07/bluenoroff-zoom-phishing-kit-profiles.html>

04. Hotel Wi-Fi Routers Compromised to Steal Corporate Login Credentials From Visitors

Researchers at ReliaQuest warned of widespread DNS poisoning attacks targeting the hospitality sector as part of a cyber espionage campaign

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://www.infosecurity-magazine.com/news/hotel-wifi-dns-poisoning/>

05. Beyond the Play Store: How Android threats really spread

Some threats never pass through the Play Store. Others arrive later in seemingly legitimate updates. Here's how Malwarebytes detects both.

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://www.malwarebytes.com/blog/inside-malwarebytes/2026/07/beyond-the-play-store-how-android-threats-really-spread>

06. ChatGPT Among Top 10 Most Impersonated Brands in Phishing Attacks, Says Check Point

OpenAI's chatbot tool ChatGPT ranked among the top 10 most impersonated brands in phishing attacks for the first time

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Tighten email authentication and filtering, run targeted user awareness, and monitor for lookalike domains and suspicious inbox rules.

Sources: <https://www.infosecurity-magazine.com/news/chatgpt-most-impersonated-brands/>

07. Top AIs invent same fake PyPI and npm package names

Enterprise software developers continue to be in danger of falling victim to slopsquatting, where AI coding tools hallucinate the existence of nonexistent libraries and hackers create malicious packages in response. The top AI coding tools are remarkably consistent in their hallucinations: Researcher Aleksandr Churilov found the same 127 fake package names...

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://www.csoonline.com/article/4201164/top-ais-invent-same-fake-pypl-and-npm-package-names-2.html>

08. Tycoon2FA takedown reshapes the phishing landscape

Traditional phishing techniques are in decline as a result of the disruption of the Tycoon2FA phishing-as-a-service (PHaaS) platform, Microsoft said in a new report, "Email threat landscape: Q2 2026 trends and insights". "Phishing volume linked to the platform fell 92% from pre-disruption averages, including QR code phishing and CAPTCHA-gated phishing both...

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Tighten email authentication and filtering, run targeted user awareness, and monitor for lookalike domains and suspicious inbox rules.

Sources:

<https://www.csoonline.com/article/4201146/tycoon2fa-takedown-reshapes-the-phishing-landscape.html>

09. Golden Chickens Resurfaces With Four New Malware Families and Modular Implants

The threat actors behind the Golden Chickens malware-as-a-service (MaaS) ecosystem have resurfaced with four new malware families, indicating that the operators are showing no signs of stopping despite extensive public disclosures into their inner workings. The malware families in question are: TinyEgg, ChonkyChicken, a modularized variant of ChonkyChicken,...

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://thehackernews.com/2026/07/golden-chickens-resurfaces-with-four.html>

10. [+24h Old] Fake Notepad++ Plugin Delivers MATCHBOIL.V2 in UAC-0099 Attacks

The Computer Emergency Response Team of Ukraine (CERT-UA) has warned of a new campaign that involves the use of a malicious program that's dressed up as a Notepad++ plugin to compromise Windows systems. The activity has been attributed by the agency to a threat cluster it tracks as UAC-0099, a Russia-aligned group that has previously observed weaponizing se...

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://thehackernews.com/2026/07/fake-notepad-plugin-delivers.html>

Latest Vulnerabilities (10)

01. GitHub to implement two-tier bug bounty program amid AI-generated report surge

GitHub is launching a two-tier bug bounty program starting July 27, 2026, in response to an increase in low-quality, AI-generated vulnerability reports.

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://www.scworld.com/brief/github-to-implement-two-tier-bug-bounty-program-amid-ai-generated-report-surge>

02. AI assistant used in cyberattack on Thailand's Ministry of Finance

An open-source AI assistant named Hermes was used in a cyberattack targeting Thailand's Ministry of Finance, compromising sensitive personnel data and internal systems.

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://www.scworld.com/brief/ai-assistant-used-in-cyberattack-on-thailands-ministry-of-finance>

03. OnTrac notifies customers of data breach after network hack

OnTrac parcel delivery company is informing that hackers breached its corporate network and may have accessed personal details belonging to its customers. [...]

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://www.bleepingcomputer.com/news/security/ontrac-notifies-customers-of-data-breach-after-network-hack/>

04. Hermes AI agent used to automate attack on Thai Finance Ministry

A threat actor used the open-source Hermes AI agent in unattended "YOLO" mode to automate post-exploitation activity during an alleged breach of Thailand's Ministry of Finance. [...]

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://www.bleepingcomputer.com/news/security/hermes-ai-agent-used-to-automate-attack-on-thai-finance-ministry/>

05. Certighost Exploit Lets Low-Privileged Active Directory Users Impersonate a Domain Controller

Researchers H0j3n and Aniq Fakhrul published a working exploit on July 24 that lets a low-privileged Active Directory user obtain a certificate for a Domain Controller and authenticate as that machine. They codenamed the flaw Certighost. Because Domain Controller accounts carry directory replication rights, the resulting Kerberos credential can retrieve the...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://thehackernews.com/2026/07/certighost-exploit-lets-low-privileged.html>

06. Slopsquatting, Phantom Domains, and HalluSquatting Are the Same AI Attack

Slopsquatting, phantom squatting, and HalluSquatting all exploit the same late-binding attack pattern, where AI coding agents trust hallucinated package, repo, or domain names. ActiveState explains how pre-fetch verification and governed dependency management can help stop these attacks before malicious code enters the pipeline. [...]

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://www.bleepingcomputer.com/news/security/slopsquatting-phantom-domains-and-hallusquatting-are-the-same-ai-attack/>

07. Meta tackles AI-generated accounts with a free Facebook verification badge

Meta has introduced Facebook Verified, a free badge meant to show that a person behind a profile has completed identity verification through a selfie check. (Source: Meta) The company says the goal is to give users a signal that they are dealing with a person, not a bot or an AI-generated account, when browsing Marketplace listings, dating profiles, or Grou...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://www.helpnetsecurity.com/2026/07/24/meta-facebook-verified-badge-selfie-verification/>

08. Russian hackers exploit unpatched Zimbra servers to steal emails

Russian state-backed hacker group Laundry Bear has been breaking into government and commercial networks for at least a year by exploiting a vulnerability in the Zimbra Collaboration Suite (ZCS) webmail platform. Laundry Bear (also known as Void Blizzard, CL-STA-1114, and TA488) has been running the campaign since July 2025, according to a joint advisory fr...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources:

<https://www.helpnetsecurity.com/2026/07/24/laundry-bear-zimbra-vulnerability-cve-2025-66376/>

09. ChatGPT AgentForger Flaw Could Deploy Rogue Workspace Agents via a Phishing Link

Cybersecurity researchers have disclosed a critical vulnerability in OpenAI's ChatGPT Workspace Agents that could have allowed a single phishing link to stealthily build, authorize, and deploy an autonomous artificial intelligence (AI) agent inside a victim's organization. The vulnerability has been codenamed AgentForger by Zenity Labs. The issue has since...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://thehackernews.com/2026/07/chatgpt-agentforger-flaw-could-deploy.html>

10. Bing Images Flaws Let Crafted SVGs Run Commands as SYSTEM on Microsoft's Servers

A crafted SVG submitted to Bing's image search ran commands as NT AUTHORITY\SYSTEM on Microsoft's production image-processing workers, and as root on the Linux machines in the same fleet. XBOW's testing got the same result on workers across different hosts and network ranges, so the problem sat in Bing's image tier, not on one bad machine. Microsoft issued...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://thehackernews.com/2026/07/bing-images-flaws-let-crafted-svg-run.html>

Data Breach & Cybercrime (10)

01. Pope's official prayer app commits cardinal sin, leaks 700K+ users' info (Security) hole-ier than thou

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.theregister.com/security/2026/07/24/popes-official-prayer-app-commits-cardinal-sin-leaks-700k-users-info/5278603>

02. Vatican's 'Click to Pray' app leaks personal data of hundreds of thousands

A popular Vatican website and mobile app, 'Click to Pray,' was found to be leaking the names and email addresses of hundreds of thousands of its users.

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources:

<https://www.scworld.com/brief/vaticans-click-to-pray-app-leaks-personal-data-of-hundreds-of-thousands>

03. Cybersecurity threats escalate with ransomware, data breaches and online fraud

The cybersecurity landscape continues to expand with increasing risks for governments, businesses and consumers.

Why it matters: Ransomware operations combine disruption with extortion, making recovery speed and data-resilience core business risks.

Recommendation: Verify offline backups, test restores, harden remote access, and review segmentation to limit lateral movement.

Sources: <https://www.scworld.com/brief/cybersecurity-threats-escalate-with-ransomware-data-breaches-and-online-fraud>

04. US to deny visas to foreign nationals involved in cybercrime

The United States will deny visas to foreign nationals involved in cybercrime, with potential extensions to their immediate families, according to a recent report by The Register.

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.scworld.com/brief/us-to-deny-visas-to-foreign-nationals-involved-in-cybercrime>

05. Don't get fooled by TikTok resin art scams

Scammers are using stolen videos and fake artist profiles to trick people into buying resin art that never arrives. Here's how to spot the warning signs.

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.malwarebytes.com/blog/scams/2026/07/dont-get-fooled-by-tiktok-resin-art-scams>

06. Call of Duty Mobile scam uses fake free points to steal player accounts

A phishing site posing as a free Call of Duty Points giveaway is stealing Activision logins and two-factor authentication codes.

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.malwarebytes.com/blog/threat-intel/2026/07/call-of-duty-mobile-scam-uses-fake-free-points-to-steal-player-accounts>

07. In Other News: Dolphin X AI-Powered Malware, Car Anti-Theft Device Hack, 400 Linux Kernel Flaws

Noteworthy stories that might have slipped under the radar: Siemens ROX II industrial switch vulnerabilities, Russian Zimbra webmail espionage campaign, Stadler Rail ransomware extortion attempt. The post In Other News: Dolphin X AI-Powered Malware, Car Anti-Theft Device Hack, 400 Linux Kernel Flaws appeared first on SecurityWeek .

Why it matters: Ransomware operations combine disruption with extortion, making recovery speed and data-resilience core business risks.

Recommendation: Verify offline backups, test restores, harden remote access, and review segmentation to limit lateral movement.

Sources: <https://www.securityweek.com/in-other-news-dolphin-x-ai-powered-malware-car-anti-theft-device-hack-400-linux-kernel-flaws/>

08. Chick-fil-A data breach affects more than 13,000 customers

Chick-fil-A has confirmed that over 13,000 customers had their accounts breached in a wave of credential stuffing attacks targeting its website and mobile app between June 17 and June 19. [...]

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.bleepingcomputer.com/news/security/chick-fil-a-data-breach-affects-more-than-13-000-customers/>

09. The Good, the Bad and the Ugly in Cybersecurity - Week 30

Authorities arrest Kratos's developer, HollowGraph hides C2 in 2050 calendar events, and OpenAI's models breach Hugging Face to steal benchmark answers.

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.sentinelone.com/blog/the-good-the-bad-and-the-ugly-in-cybersecurity-week-30-8/>

10. Vatican's Official Prayer App Leaks 700K+ Global Users' PII

A porous API endpoint exposes, names, email addresses, country, and site status, all of which can be easily gleaned by anyone with a browser.

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.darkreading.com/vulnerabilities-threats/vatican-official-prayer-app-leaks-700k-pii>